

PeerLink / P2P Cybersecurity Remediation Report

Remediation summary for the 11 KACST cybersecurity findings.

Project: PeerLink / P2P-V2 **Report date:** 2026-06-07 **Production URL:** <https://p2p.iiootsolutions.sa> **Scope:** KACST cybersecurity review findings and remediation summary

Summary

KACST reported 11 cybersecurity findings for PeerLink/P2P. All findings have been reviewed and addressed. Below is the remediation summary for each security issue.

Remediation Summary

1. Outdated NGINX 1.24.0 with critical/high vulnerabilities

The server package was checked and confirmed to be on the latest available patched Ubuntu release. The public version banner was also hidden to prevent scanner-based version exposure.

2. Login exposed over plain HTTP

HTTPS was enabled for the public website, and HTTP traffic is now redirected to HTTPS.

3. Unrestricted file upload vulnerability

File uploads were restricted and validated so unsafe, spoofed, oversized, or unauthorized uploads are blocked.

4. Login implemented without 2FA/MFA

Login security was strengthened with OTP-based verification/MFA behavior.

5. Outdated and vulnerable frontend libraries

Frontend dependencies were updated and verified until the audit showed no remaining vulnerabilities.

6. Web server version disclosure via HTTP response headers

The web server no longer exposes the exact NGINX/Ubuntu version in public response headers.

7. Missing HTTP Strict Transport Security / HSTS header

HSTS was added so browsers are instructed to use HTTPS for the site.

8. Missing Content Security Policy / CSP header

A safe CSP header was added to reduce the risk of browser-side script injection while keeping the site functional.

9. Lack of input validation across application fields

Application forms were hardened so suspicious input, invalid values, and common scanner payloads are rejected.

10. Application implemented using HTTP/1.1

HTTP/2 was enabled on the secure public endpoint.

11. Unauthorized change of corporate email to personal email after login

Email-change rules were strengthened so users cannot switch from an approved corporate email to a personal email.

Final Status

All 11 KACST cybersecurity findings have been addressed.

Key security improvements now in place:

- HTTPS enforced
- HTTP/2 enabled
- HSTS enabled
- CSP enabled

- Web server version hidden
- Upload validation strengthened
- Frontend vulnerabilities cleared
- OTP/MFA behavior added
- Input validation strengthened
- Corporate email-change restrictions added